

Scenario 2 output 2 chatgpt

Threat 1 — Unauthorized File Retrieval

- **Threat ID:** T1
- **Threat name:** Broken File Access Control
- **Category:** STRIDE – Elevation of Privilege / Authorization
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker manipulates a file retrieval request, filename, file identifier, or associated metadata to request a file they do not own or have permission to access. If P2 incorrectly validates permissions or trusts attacker-controlled identifiers, the attacker can retrieve another user's document.
- **Impact:** Confidentiality breach, exposure of private documents, privacy violations, and potential disclosure of sensitive business information.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must perform authorization checks for every retrieval request against the authoritative DS2 permission records. Never rely on filenames, client-supplied ownership information, or frontend checks. Enforce deny-by-default authorization.
- **OWASP mapping:** OWASP LLM01 – Prompt Injection is not the primary mapping; this is primarily broken access control. Relevant LLM risk: LLM06 – Excessive Agency if the AI were able to retrieve files, although the architecture explicitly prevents this.

Threat 2 — Authorization Bypass Through the AI Assistant

- **Threat ID:** T2
- **Threat name:** AI-Mediated Authorization Bypass
- **Category:** Authorization / LLM-specific
- **Affected component/data flow:** EE1 → P1 → P3/P4 → DS1
- **Attack description:** A user attempts to convince P3 or P4 to retrieve, reveal, or provide information from a document that the user is not authorized to access. This could occur through instructions such as "ignore the permission restrictions" or "show me the contents of the other document."
- **Impact:** Unauthorized disclosure of protected documents.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation:** Maintain the architectural restriction that P3 and P4 cannot retrieve files or make authorization decisions. P2 must authorize access before any document context reaches P3. Treat all AI requests as untrusted and never allow AI-generated instructions to override P2.
- **OWASP mapping:** LLM01 – Prompt Injection; LLM06 – Excessive Agency.

Threat 3 — Direct Prompt Injection Through Uploaded Documents

- **Threat ID:** T3
- **Threat name:** Document-Based Prompt Injection
- **Category:** LLM-specific / STRIDE – Tampering

- **Affected component/data flow:** EE1 → P1 → P2 → DS1 → P3 → P4 → EE2
- **Attack description:** An attacker uploads a malicious document containing instructions such as "ignore previous instructions," "reveal system information," or instructions designed to manipulate the AI assistant. When an authorized user later asks questions about the document, the malicious content becomes part of the AI context.
- **Impact:** Manipulated AI responses, disclosure of information present in the authorized context, unsafe processing, and potentially unintended instructions being followed by the model.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat document contents as untrusted data, not instructions. Clearly separate system instructions from document content. Sanitize and delimit retrieved document content. Apply prompt-injection-resistant prompting and validate generated output before displaying it.
- **OWASP mapping:** LLM01 – Prompt Injection.

Threat 4 — Indirect Prompt Injection From Malicious Documents

- **Threat ID:** T4
- **Threat name:** Indirect Prompt Injection via Document Content
- **Category:** LLM-specific
- **Affected component/data flow:** DS1 → P3 → P4 → EE2
- **Attack description:** A malicious instruction embedded inside a document is unintentionally interpreted as an instruction by the LLM rather than as document content. The attack is indirect because the attacker does not directly control the user's AI query.
- **Impact:** Incorrect answers, manipulation of the AI assistant, unintended disclosure of information within the approved context, and potentially malicious downstream behavior.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Establish strong semantic separation between instructions and retrieved content. Label document text as untrusted content, use delimiters, minimize context, and instruct the model explicitly that document instructions must not be followed.
- **OWASP mapping:** LLM01 – Prompt Injection.

Threat 5 — Malicious File Content

- **Threat ID:** T5
- **Threat name:** Malicious Document Payload
- **Category:** File Security
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker uploads a malicious file designed to exploit document-processing behavior or abuse how file contents are handled. The malicious content may also be constructed to manipulate the AI assistant when later processed.
- **Impact:** File integrity compromise, denial of service, malicious content propagation, and AI manipulation.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Validate file types, enforce file-size limits, reject unsupported formats, validate file structure, safely process uploaded content, and treat all uploaded content as untrusted.
- **OWASP mapping:** Primarily file-security risk; LLM01 – Prompt Injection where malicious content targets the LLM.

Threat 6 — Unauthorized Document Context Passed to AI

- **Threat ID:** T6
- **Threat name:** Context Authorization Failure
- **Category:** Data Leakage / Authorization
- **Affected component/data flow:** P2 → P3 → P4 → EE2
- **Attack description:** P3 receives document context that was not properly authorized by P2. This violates the stated architecture in which AI receives only authorization-approved document context.
- **Impact:** Sensitive document disclosure to the AI processing chain and potentially to EE2.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation:** Make P2 authorization a mandatory prerequisite for context generation. P3 must accept only explicitly approved context. Do not allow P3 to independently query DS1.
- **OWASP mapping:** LLM06 – Excessive Agency; LLM02 – Sensitive Information Disclosure.

Threat 7 — Sensitive Information Disclosure Through LLM Responses

- **Threat ID:** T7
- **Threat name:** Sensitive Context Leakage
- **Category:** Data Leakage / LLM-specific
- **Affected component/data flow:** P3 → P4 → EE2 → P4/P3 → EE1
- **Attack description:** Even when the supplied document context is authorized, the LLM may reproduce sensitive information unnecessarily in its response. The model may expose confidential portions of the document when answering a broad or adversarial question.
- **Impact:** Disclosure of confidential document information.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize context sent to the LLM, provide only the information required to answer the question, instruct the model to avoid unnecessary sensitive information, and validate output before returning it to the user.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure.

Threat 8 — Leakage of Private Metadata

- **Threat ID:** T8
- **Threat name:** Metadata Exposure
- **Category:** Data Leakage
- **Affected component/data flow:** DS1 → P2/P3/P4 → EE2
- **Attack description:** File metadata that should remain private could accidentally be incorporated into the context or sanitized prompt and transmitted to EE2.
- **Impact:** Disclosure of filenames, ownership information, internal metadata, or other sensitive document attributes.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Explicitly exclude private metadata from AI context. Implement data minimization before P4 sends information to EE2 and verify that only approved document content is included.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure.

Threat 9 — Permission Database Exposure

- **Threat ID:** T9
- **Threat name:** Authorization Data Disclosure
- **Category:** STRIDE – Information Disclosure
- **Affected component/data flow:** P2 ↔ DS2
- **Attack description:** An attacker attempts to cause the AI assistant, frontend, or another process to expose DS2 contents, including ownership and permission information.
- **Impact:** Disclosure of authorization relationships and sensitive user/file access information.
- **Severity:** Critical
- **Likelihood:** Low
- **Mitigation:** DS2 must remain accessible only to P2 for authorization purposes. Never include DS2 contents in AI context or prompts. Do not allow P3/P4 to query DS2.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure; LLM06 – Excessive Agency.

Threat 10 — Prompt Injection Through User Questions

- **Threat ID:** T10
- **Threat name:** Adversarial User Prompt
- **Category:** LLM-specific
- **Affected component/data flow:** EE1 → P1 → P3 → P4 → EE2
- **Attack description:** A user deliberately constructs prompts intended to override the assistant's instructions, extract hidden context, manipulate document interpretation, or induce disclosure of information contained in the approved context.
- **Impact:** Unreliable responses, sensitive-context leakage, and manipulation of AI behavior.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat user prompts as untrusted. Separate instructions from user content, use strict system-level policies, minimize context, and validate responses for unintended disclosure.
- **OWASP mapping:** LLM01 – Prompt Injection.

Threat 11 — LLM Output Manipulation

- **Threat ID:** T11
- **Threat name:** Untrusted LLM Output
- **Category:** LLM-specific / STRIDE – Tampering
- **Affected component/data flow:** EE2 → P4 → P3 → P1 → EE1
- **Attack description:** The external LLM generates incorrect, manipulated, hallucinated, or adversarial content. The architecture explicitly states that LLM output is untrusted.
- **Impact:** Users may receive false document interpretations or incorrect security-relevant information.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Treat generated output as untrusted data. Validate and constrain output before presentation. Clearly distinguish generated interpretation from authoritative file contents.
- **OWASP mapping:** LLM09 – Misinformation.

Threat 12 — LLM Hallucination of Document Information

- **Threat ID:** T12
- **Threat name:** Fabricated Document Content
- **Category:** LLM-specific

- **Affected component/data flow:** P3/P4 → EE1
- **Attack description:** The LLM generates information that is not actually present in the authorization-approved document context.
- **Impact:** Users may make decisions based on inaccurate information.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Require answers to remain grounded in supplied document context, request source references or supporting passages where appropriate, and clearly identify generated interpretations.
- **OWASP mapping:** LLM09 – Misinformation.

Threat 13 — Excessive AI Permissions

- **Threat ID:** T13
- **Threat name:** Excessive AI Authority
- **Category:** Authorization / LLM-specific
- **Affected component/data flow:** P3/P4 ↔ P2/DS1
- **Attack description:** If implementation accidentally gives P3 or P4 direct access to DS1 or authorization capabilities, the AI could become an alternative path around P2.
- **Impact:** Potential compromise of the entire file authorization model.
- **Severity:** Critical
- **Likelihood:** Low under the stated architecture
- **Mitigation:** Enforce least privilege technically. P3 and P4 must not have direct DS1 access or DS2 access and must not be capable of changing authorization decisions.
- **OWASP mapping:** LLM06 – Excessive Agency.

Threat 14 — Authorization Confusion Through User-Supplied Metadata

- **Threat ID:** T14
- **Threat name:** Metadata-Based Authorization Bypass
- **Category:** Authorization / STRIDE – Elevation of Privilege
- **Affected component/data flow:** EE1 → P1 → P2 → DS2
- **Attack description:** The attacker modifies a filename, user identifier, ownership field, file ID, or other request metadata in an attempt to convince P2 that the requested document belongs to them.
- **Impact:** Unauthorized access to another user's files.
- **Severity:** Critical
- **Likelihood:** Medium
- **Mitigation:** P2 must obtain ownership and permissions exclusively from authoritative DS2 records. Never trust authorization attributes supplied by EE1 or P1.
- **OWASP mapping:** Not primarily an OWASP LLM risk; relevant to broken access control.

Threat 15 — File Identifier Enumeration

- **Threat ID:** T15
- **Threat name:** File Reference Enumeration
- **Category:** Authorization / Information Disclosure
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker repeatedly submits different file identifiers or filenames to discover whether files belonging to other users exist.
- **Impact:** Disclosure of file existence, filenames, metadata, or potentially document contents if authorization fails.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Perform authorization before revealing file existence. Use non-predictable file identifiers where applicable and return generic responses for unauthorized requests.
- **OWASP mapping:** Not primarily an LLM-specific threat.

Threat 16 — File Storage Tampering

- **Threat ID:** T16
- **Threat name:** Unauthorized File Modification
- **Category:** STRIDE – Tampering
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker attempts to manipulate upload or storage operations to overwrite another user's document or modify protected file metadata.
- **Impact:** Loss of data integrity, corruption of documents, and potential downstream AI manipulation.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** P2 must authorize storage operations as well as retrieval. Verify file ownership and permissions before modifications and prevent users from overwriting resources they do not control.
- **OWASP mapping:** Not primarily an LLM-specific threat.

Threat 17 — Malicious File Overwrite for AI Manipulation

- **Threat ID:** T17
- **Threat name:** Authorized-Context Poisoning
- **Category:** File Security / LLM-specific
- **Affected component/data flow:** EE1 → P2 → DS1 → P3/P4
- **Attack description:** An attacker who legitimately controls a document replaces or modifies its contents with carefully crafted instructions designed to manipulate the AI when another authorized user asks questions about that document.
- **Impact:** Persistent prompt injection, manipulated answers, misinformation, and potential disclosure of information already present in the approved context.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Treat stored documents as untrusted even after authorization. Detect suspicious instruction-like content and maintain document integrity controls and versioning where applicable.
- **OWASP mapping:** LLM01 – Prompt Injection; LLM09 – Misinformation.

Threat 18 — Prompt Construction Failure

- **Threat ID:** T18
- **Threat name:** Insecure LLM Context Construction
- **Category:** LLM-specific / Data Leakage
- **Affected component/data flow:** P3 → P4 → EE2
- **Attack description:** P4 creates a sanitized prompt but fails to properly isolate user questions from document content or includes unnecessary sensitive information in the prompt.
- **Impact:** Prompt injection, context confusion, sensitive information exposure, and manipulated responses.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply strict context separation, explicit delimiters, data minimization, prompt templates, and validation of the final prompt before transmission.
- **OWASP mapping:** LLM01 – Prompt Injection; LLM02 – Sensitive Information Disclosure.

Threat 19 — External LLM Provider Data Exposure

- **Threat ID:** T19
- **Threat name:** External Provider Confidentiality Risk
- **Category:** Data Leakage / Third-Party Risk
- **Affected component/data flow:** P4 → EE2
- **Attack description:** Authorization-approved document context is transmitted to an external LLM provider outside application control. The provider therefore becomes a third-party processing point for potentially sensitive document information.
- **Impact:** Confidentiality and privacy risks associated with external processing, retention, logging, or provider-side compromise.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Minimize the context transmitted to EE2, ensure only necessary information is sent, apply the stated sanitization requirements, and establish appropriate provider security and data-handling controls.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure; LLM03 – Supply Chain.

Threat 20 — External LLM Compromise or Malicious Behavior

- **Threat ID:** T20
- **Threat name:** Compromised External LLM Provider
- **Category:** STRIDE – Information Disclosure / LLM Supply Chain
- **Affected component/data flow:** P4 ↔ EE2
- **Attack description:** EE2 is outside application control. A compromise or malicious behavior at the external provider could expose or manipulate the document context or generated responses.
- **Impact:** Confidentiality breach, manipulated responses, loss of trust, and potential exposure of sensitive document information.
- **Severity:** High
- **Likelihood:** Low
- **Mitigation:** Minimize sensitive information sent to EE2, treat all returned output as untrusted, and limit the information exposed to the external provider to the minimum required for the requested task.
- **OWASP mapping:** LLM03 – Supply Chain; LLM02 – Sensitive Information Disclosure.

Threat 21 — Denial of Service Through Large File Uploads

- **Threat ID:** T21
- **Threat name:** Resource Exhaustion via File Upload
- **Category:** STRIDE – Denial of Service
- **Affected component/data flow:** EE1 → P1 → P2 → DS1
- **Attack description:** An attacker uploads extremely large or numerous files to consume available storage or processing resources.
- **Impact:** Reduced availability of file management functionality and potential inability to process legitimate documents.

- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Enforce file-size and upload constraints, restrict upload frequency, and reject unsupported or excessively large files.
- **OWASP mapping:** LLM04 – Model Denial of Service where excessive processing reaches the AI workflow.

Threat 22 — Denial of Service Through AI Queries

- **Threat ID:** T22
- **Threat name:** LLM Resource Exhaustion
- **Category:** Availability / LLM-specific
- **Affected component/data flow:** EE1 → P3 → P4 → EE2
- **Attack description:** An attacker submits repeated, extremely long, or computationally expensive document questions to cause excessive LLM processing.
- **Impact:** Resource exhaustion, increased processing cost, degraded availability, and reduced service responsiveness.
- **Severity:** High
- **Likelihood:** Medium
- **Mitigation:** Apply request limits, input-size limits, context-size limits, and appropriate rate controls before requests reach the LLM integration service.
- **OWASP mapping:** LLM04 – Model Denial of Service.

Threat 23 — Data Integrity Loss During LLM Processing

- **Threat ID:** T23
- **Threat name:** Incorrect Document Interpretation
- **Category:** STRIDE – Tampering / LLM-specific
- **Affected component/data flow:** DS1 → P3 → P4 → EE2 → P3 → EE1
- **Attack description:** The original document is not modified, but the LLM produces an inaccurate interpretation that changes the apparent meaning of the document for the user.
- **Impact:** Users may misunderstand contractual, technical, financial, or operational information contained in files.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Ground responses in the supplied document context, preserve original document content as authoritative, and communicate that AI-generated explanations are not authoritative replacements for the source document.
- **OWASP mapping:** LLM09 – Misinformation.

Threat 24 — Information Disclosure Through Error Responses

- **Threat ID:** T24
- **Threat name:** Unauthorized Error-Based Disclosure
- **Category:** STRIDE – Information Disclosure
- **Affected component/data flow:** EE1 → P1 → P2 → DS1/DS2 → P1 → EE1
- **Attack description:** Error messages generated during unauthorized file requests could reveal whether a file exists, who owns it, its metadata, or details about permission rules.
- **Impact:** Information leakage and assistance to subsequent authorization attacks.
- **Severity:** Medium
- **Likelihood:** Medium

- **Mitigation:** Return generic authorization failures to unauthorized users and avoid exposing internal storage, permission, or metadata details.
- **OWASP mapping:** Not primarily an LLM-specific threat.

Threat 25 — AI-Assisted Sensitive Information Extraction

- **Threat ID:** T25
- **Threat name:** Adversarial Extraction From Authorized Context
- **Category:** LLM-specific / Data Leakage
- **Affected component/data flow:** EE1 → P3 → P4 → EE2 → P3 → EE1
- **Attack description:** A user who legitimately has access to a document uses carefully crafted questions to force the LLM to expose information that the application intended to present only in a limited or summarized manner.
- **Impact:** Excessive disclosure of sensitive information contained within an otherwise authorized document.
- **Severity:** Medium
- **Likelihood:** High
- **Mitigation:** Apply output controls, minimize context, avoid unnecessary inclusion of sensitive sections, and define clear rules for what information the assistant should reveal.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure; LLM01 – Prompt Injection.

Threat 26 — Trust Boundary Abuse at the External User Environment

- **Threat ID:** T26
- **Threat name:** Untrusted Client Input
- **Category:** STRIDE – Tampering
- **Affected component/data flow:** EE1 → P1
- **Attack description:** EE1 is explicitly outside the trusted system boundary. The attacker can manipulate uploads, filenames, metadata, retrieval parameters, and questions before they reach P1.
- **Impact:** Injection attacks, authorization manipulation attempts, malicious file uploads, and AI prompt injection.
- **Severity:** High
- **Likelihood:** High
- **Mitigation:** Treat every value received from EE1 as untrusted. Perform validation and authorization on the server side and never rely on client-side security controls.
- **OWASP mapping:** LLM01 – Prompt Injection where malicious input reaches the AI workflow.

Threat 27 — Spoofing of User Identity

- **Threat ID:** T27
- **Threat name:** User Identity Spoofing
- **Category:** STRIDE – Spoofing
- **Affected component/data flow:** EE1 → P1 → P2 → DS2
- **Attack description:** An attacker attempts to make P2 associate a request with another user's identity so that DS2 returns permissions belonging to the victim.
- **Impact:** Unauthorized file access.
- **Severity:** Critical
- **Likelihood:** Medium

- **Mitigation:** P2 must use the authenticated identity associated with the request rather than attacker-supplied identity information. Authorization must be based on the authoritative identity and permission information in DS2.
- **OWASP mapping:** Primarily authentication/access-control risk rather than an LLM-specific risk.

Threat 28 — Repudiation of File Operations

- **Threat ID:** T28
- **Threat name:** Untraceable File Access or Upload
- **Category:** STRIDE – Repudiation
- **Affected component/data flow:** EE1 → P1 → P2 → DS1/DS2
- **Attack description:** Without sufficient records of file operations, a user may deny having uploaded, retrieved, or modified a document.
- **Impact:** Difficulty investigating unauthorized access, malicious uploads, and data-integrity incidents.
- **Severity:** Medium
- **Likelihood:** Medium
- **Mitigation:** Maintain appropriate records of authorization decisions and file operations, including the relevant user, resource, operation, and result.
- **OWASP mapping:** Not primarily an LLM-specific threat.

Threat 29 — Tampering With Authorization Records

- **Threat ID:** T29
- **Threat name:** Permission Database Manipulation
- **Category:** STRIDE – Tampering / Authorization
- **Affected component/data flow:** P2 ↔ DS2
- **Attack description:** If an attacker can modify DS2, they could change ownership or permissions and cause P2 to authorize access that should not be permitted.
- **Impact:** System-wide authorization compromise and unauthorized access to protected files.
- **Severity:** Critical
- **Likelihood:** Low under the stated architecture
- **Mitigation:** Protect DS2 integrity, restrict modification capability to authorized operations, and ensure P2 treats DS2 as the authoritative source rather than accepting permission information from other components.
- **OWASP mapping:** Not primarily LLM-specific.

Threat 30 — AI Context Overexposure

- **Threat ID:** T30
- **Threat name:** Excessive Context Disclosure
- **Category:** Data Leakage / LLM-specific
- **Affected component/data flow:** P2 → P3 → P4 → EE2
- **Attack description:** P2 correctly authorizes a document, but P3/P4 send substantially more of the document than is required to answer the user's question. Authorization to access a document does not eliminate the need for data minimization.
- **Impact:** Unnecessary exposure of confidential information to P4 and EE2 and increased consequences if the LLM interaction is compromised.
- **Severity:** High
- **Likelihood:** Medium

- **Mitigation:** Apply least-privilege principles to AI context. Send only the minimum relevant document content required to answer each question and exclude unrelated sensitive sections.
- **OWASP mapping:** LLM02 – Sensitive Information Disclosure; LLM06 – Excessive Agency.